

GUÍA DE PISTAS

Análisis de Sistema Operativo y Configuración con Lynis

Actividad AE1.2 - Fase 1

Esta guía te ayudará a descubrir por ti mismo las vulnerabilidades de **configuración y sistema operativo** en Metasploitable 2 usando Lynis.

No encontrarás respuestas directas, sino pistas que te guiarán en tu investigación. Tu trabajo es seguir las pistas, ejecutar comandos y **documentar tus hallazgos**.

■■ Duración estimada:	90-120 minutos
■ Objetivo:	Encontrar 8-12 vulnerabilidades de configuración/SO
■ Metodología:	Investigación guiada con pistas
■ Herramienta:	Lynis + comandos sistema

CÓMO USAR ESTA GUÍA

1. LEE CADA SECCIÓN COMPLETA antes de ejecutar comandos
2. EJECUTA EL COMANDO PRINCIPAL (normalmente Lynis)
3. SIGUE LAS PISTAS para interpretar los resultados
4. INVESTIGA MÁS con comandos adicionales si se sugieren
5. DOCUMENTA lo que encuentres en tu informe
6. RESPONDE LAS PREGUNTAS de análisis crítico

■■ IMPORTANTE

No te limites a copiar los resultados de Lynis. Tu trabajo es **ANALIZAR**, **INTERPRETAR** y **EXPLICAR** qué significa cada vulnerabilidad encontrada y por qué es importante.

PASO 0: PREPARACIÓN INICIAL

Antes de comenzar, asegúrate de:

- ✓ Estar conectado por SSH a Metasploitable 2 (usuario: msfadmin)
- ✓ Tener Lynis instalado (viene preinstalado en Metasploitable 2)
- ✓ Tener permisos sudo con el usuario msfadmin

Comando para verificar que Lynis está disponible:

```
lynis --version
```

Comando principal que usarás constantemente:

```
sudo lynis audit system
```

■ *Este comando ejecuta una auditoría completa del sistema. Tarda 3-5 minutos.*

■ INVESTIGACIÓN 1: VERSIÓN DEL KERNEL

El kernel es el núcleo del sistema operativo. Un kernel obsoleto contiene vulnerabilidades críticas.

Paso 1: Ejecuta Lynis y busca información del kernel

```
sudo lynis audit system
```

- *Pista 1: Busca en el output una sección llamada 'Kernel'. Mira las primeras líneas del escaneo.*
- *Pista 2: Lynis muestra un código de warning relacionado con KRNL-XXXX. Anótalo.*
- *Pista 3: Lynis te dirá que la versión es 'muy antigua' (very old).*

Paso 2: Verifica manualmente la versión del kernel

```
uname -r
```

- *Pista 4: El resultado debe mostrar algo como 2.6.24-XXXXX*

Paso 3: Investiga cuándo se lanzó ese kernel

- *Pista 5: El kernel 2.6.24 se lanzó en enero de 2008. Estamos en 2025...*

■ PREGUNTAS PARA TU INFORME:

1. ¿Qué versión del kernel tiene Metasploitable 2?
2. ¿Cuántos AÑOS tiene este kernel desactualizado?
3. ¿Qué código de warning de Lynis hace referencia a esto? (KRNL-XXXX)
4. ¿Por qué es peligroso usar un kernel tan antiguo?
5. ¿Qué tipo de vulnerabilidades podría tener un kernel de 17 años?

■ INVESTIGACIÓN 2: SEGURIDAD DE USUARIOS

Los usuarios sin contraseña son una vulnerabilidad CRÍTICA. Cualquiera puede acceder al sistema.

Paso 1: Busca warnings sobre autenticación en Lynis

```
sudo lynis audit system
```

■ *Pista 1: Busca en el output la sección 'Authentication' o 'Users, Groups and Authentication'.*

■ *Pista 2: Lynis mostrará un código AUTH-XXXX relacionado con cuentas sin password.*

■ *Pista 3: La suggestion dirá algo como 'Set password for accounts...'.*

Paso 2: Examina el archivo de contraseñas

```
sudo cat /etc/shadow | grep -v '^#' | grep -v '!' | head -10
```

■ *Pista 4: En /etc/shadow, un campo vacío (::) significa sin contraseña.*

■ *Pista 5: Busca líneas que tengan dos puntos consecutivos :: después del nombre de usuario.*

Paso 3: Lista los usuarios del sistema

```
cat /etc/passwd | grep -E '/bin/(bash|sh)$' | cut -d: -f1
```

■ *Pista 6: Este comando muestra usuarios con shell interactiva (pueden hacer login).*

■ PREGUNTAS PARA TU INFORME:

1. ¿Qué código de warning de Lynis detecta usuarios sin contraseña? (AUTH-XXXX)
2. ¿Cuántos usuarios con shell interactiva existen en el sistema?
3. ¿Hay algún usuario sin contraseña? ¿Cuál?
4. ¿Por qué es crítico que un usuario no tenga contraseña?
5. ¿Qué podría hacer un atacante con esta vulnerabilidad?

■ INVESTIGACIÓN 3: SEGURIDAD SSH

SSH es la puerta de entrada al sistema. Una mala configuración permite accesos no autorizados.

Paso 1: Busca warnings SSH en Lynis

```
sudo lynis audit system | grep -i ssh
```

- *Pista 1: Busca códigos SSH-XXXX en los warnings y suggestions.*
- *Pista 2: Presta atención a 'PermitRootLogin' y 'Password Authentication'.*

Paso 2: Examina la configuración SSH directamente

```
sudo cat /etc/ssh/sshd_config | grep -v '^#' | grep -v '^$'
```

- *Pista 3: Busca la línea 'PermitRootLogin'. Si dice 'yes', root puede entrar por SSH.*
- *Pista 4: Busca 'PasswordAuthentication'. Si es 'yes', acepta contraseñas (menos seguro que keys).*

Paso 3: Comprueba qué versión de SSH está instalada

```
ssh -V
```

- *Pista 5: OpenSSH 4.x es de 2006-2008, muy antiguo.*

■ PREGUNTAS PARA TU INFORME:

1. ¿Qué códigos de warning SSH detecta Lynis? (SSH-XXXX)
2. ¿Está permitido el login de root por SSH? (PermitRootLogin)
3. ¿Acepta autenticación por contraseña? (PasswordAuthentication)
4. ¿Qué versión de OpenSSH está instalada?
5. ¿Por qué es peligroso permitir root login por SSH?
6. ¿Qué método de autenticación es más seguro: password o keys?

■ INVESTIGACIÓN 4: ESTADO DEL FIREWALL

Un firewall controla el tráfico de red. Sin firewall, todos los puertos están expuestos.

Paso 1: Busca información sobre firewall en Lynis

```
sudo lynis audit system | grep -i firewall
```

■ *Pista 1: Busca códigos FIRE-XXXX o NETW-XXXX.*

■ *Pista 2: Lynis te dirá si encuentra un firewall configurado o no.*

Paso 2: Comprueba manualmente iptables

```
sudo iptables -L -n
```

■ *Pista 3: Si ves solo 3 chains vacías (INPUT, FORWARD, OUTPUT) sin reglas, NO hay firewall.*

■ *Pista 4: Fíjate en 'policy ACCEPT' - acepta todo el tráfico por defecto.*

Paso 3: Verifica si ufw está activo

```
sudo ufw status
```

■ *Pista 5: Si dice 'Status: inactive', el firewall está deshabilitado.*

■ PREGUNTAS PARA TU INFORME:

1. ¿Qué código de warning detecta Lynis sobre el firewall? (FIRE-XXXX)
2. ¿Hay reglas de firewall configuradas en iptables?
3. ¿Está ufw (Uncomplicated Firewall) activo?
4. ¿Cuál es la política por defecto? (ACCEPT/DROP)
5. ¿Qué riesgos implica no tener firewall?
6. ¿Qué servicios quedan expuestos sin protección?

■ INVESTIGACIÓN 5: GESTIÓN DE ACTUALIZACIONES

Los sistemas sin actualizar acumulan vulnerabilidades. Las actualizaciones son críticas para la seguridad.

Paso 1: Busca información sobre paquetes en Lynis

```
sudo lynis audit system | grep -i 'package\|update'
```

■ *Pista 1: Busca códigos PKGS-XXXX.*

■ *Pista 2: Lynis indicará cuándo fue la última actualización de la base de datos de paquetes.*

Paso 2: Verifica cuándo fue la última actualización

```
ls -lh /var/lib/apt/lists/ | head -5
```

■ *Pista 3: Las fechas de los archivos te dicen cuándo se actualizó por última vez.*

■ *Pista 4: Si las fechas son de 2008-2010, el sistema lleva años sin actualizar.*

Paso 3: Comprueba la versión de Ubuntu

```
lsb_release -a
```

■ *Pista 5: Ubuntu 8.04 LTS (Hardy Heron) es de abril de 2008.*

■ *Pista 6: El soporte terminó en 2013. Lleva 12 años sin soporte oficial.*

■ PREGUNTAS PARA TU INFORME:

1. ¿Qué códigos de warning sobre paquetes detecta Lynis? (PKGS-XXXX)
2. ¿Qué versión de Ubuntu está instalada?
3. ¿Cuándo fue la última actualización del sistema?
4. ¿Cuántos años hace que terminó el soporte de esta versión?
5. ¿Qué implica usar un SO sin soporte oficial?
6. ¿Podrías actualizar este sistema a una versión moderna? ¿Por qué?

■ INVESTIGACIÓN 6: CONTROLES DE ACCESO OBLIGATORIO (MAC)

SELinux y AppArmor añaden capas de seguridad adicionales. Sin ellos, los procesos tienen más permisos de los necesarios.

Paso 1: Busca información sobre MAC en Lynis

```
sudo lynis audit system | grep -i 'selinux\|apparmor\|mac'
```

■ *Pista 1: Busca códigos MACF-XXXX (Mandatory Access Control Framework).*

■ *Pista 2: Lynis dirá si encuentra algún framework MAC activo.*

Paso 2: Verifica SELinux

```
sestatus
```

■ *Pista 3: Si el comando no existe o dice 'disabled', SELinux no está activo.*

Paso 3: Verifica AppArmor

```
sudo apparmor_status
```

■ *Pista 4: Si no hay perfiles cargados o el comando falla, AppArmor no está protegiendo.*

■ PREGUNTAS PARA TU INFORME:

1. ¿Qué código de warning detecta Lynis sobre MAC? (MACF-XXXX)
2. ¿Está SELinux instalado y activo?
3. ¿Está AppArmor instalado y con perfiles cargados?
4. ¿Qué sistema MAC (si alguno) está protegiendo el sistema?
5. ¿Qué es un sistema MAC y para qué sirve?
6. ¿Qué riesgos existen sin protección MAC?

■ INVESTIGACIÓN 7: PERMISOS DE ARCHIVOS CRÍTICOS

Archivos como `/etc/shadow` contienen información sensible. Permisos incorrectos permiten lecturas no autorizadas.

Paso 1: Busca warnings sobre permisos en Lynis

```
sudo lynis audit system | grep -i 'permission\|file'
```

■ *Pista 1: Busca códigos FILE-XXXX.*

■ *Pista 2: Lynis comprueba permisos de `/etc/shadow`, `/etc/passwd`, `/etc/group`, etc.*

Paso 2: Verifica permisos de archivos críticos

```
ls -l /etc/shadow /etc/passwd /etc/group
```

■ *Pista 3: `/etc/shadow` debería ser 640 o 600 (solo root puede leer).*

■ *Pista 4: Si ves permisos como 644, cualquier usuario puede leerlo.*

Paso 3: Busca binarios con SUID/SGID

```
sudo find /usr/bin -perm -4000 -type f 2>/dev/null | head -10
```

■ *Pista 5: Binarios con SUID ejecutan con permisos del propietario, no del usuario.*

■ *Pista 6: Lynis lista estos binarios porque pueden ser explotados para escalar privilegios.*

■ PREGUNTAS PARA TU INFORME:

1. ¿Qué códigos de warning sobre permisos detecta Lynis? (FILE-XXXX)
2. ¿Qué permisos tiene el archivo `/etc/shadow`?
3. ¿Son correctos esos permisos o permiten lectura no autorizada?
4. ¿Cuántos binarios con bit SUID encuentra el comando `find`?
5. ¿Qué es el bit SUID y por qué puede ser peligroso?
6. ¿Qué información sensible hay en `/etc/shadow`?

■ INVESTIGACIÓN 8: SERVICIOS EN EJECUCIÓN

Cada servicio activo es una puerta potencial de entrada. El principio de mínimo privilegio dice: solo lo necesario debe estar activo.

Paso 1: Busca información sobre servicios en Lynis

```
sudo lynis audit system | grep -i 'service\|daemon\|boot'
```

■ *Pista 1: Busca códigos BOOT-XXXX.*

■ *Pista 2: Lynis sugiere revisar qué servicios están habilitados en el arranque.*

Paso 2: Lista servicios activos

```
ps aux | grep -v ']$' | wc -l
```

■ *Pista 3: Cuenta cuántos procesos hay ejecutándose.*

Paso 3: Identifica servicios de red

```
netstat -tuln | grep LISTEN | wc -l
```

■ *Pista 4: Cada puerto LISTEN es un servicio esperando conexiones.*

■ *Pista 5: Si ves 20+ puertos, hay muchos servicios innecesarios activos.*

■ PREGUNTAS PARA TU INFORME:

1. ¿Qué códigos de warning sobre servicios detecta Lynis? (BOOT-XXXX)
2. ¿Cuántos procesos hay ejecutándose en el sistema?
3. ¿Cuántos puertos están en estado LISTEN?
4. ¿Crees que todos estos servicios son necesarios? ¿Por qué?
5. ¿Qué principio de seguridad se viola al tener tantos servicios activos?
6. Nombra 3 servicios que detectes que NO sean esenciales para un servidor.

■ RESUMEN: SÍNTESIS DE HALLAZGOS

Una vez completadas todas las investigaciones, es momento de sintetizar tus hallazgos.

Comando final: Ver resumen de Lynis

```
sudo lynis show warnings
```

```
sudo lynis show suggestions
```

TABLA RESUMEN PARA TU INFORME

Categoría	Código Lynis	Severidad	Descripción breve
Kernel	KRNL-____	[]	
Usuarios	AUTH-____	[]	
SSH	SSH-____	[]	
Firewall	FIRE-____	[]	
Actualizaciones	PKGS-____	[]	
MAC	MACF-____	[]	
Permisos	FILE-____	[]	
Servicios	BOOT-____	[]	

Completa esta tabla con los códigos de Lynis que has encontrado. En 'Severidad' marca: CRÍTICA, ALTA, MEDIA o BAJA según tu análisis. En 'Descripción' escribe con tus propias palabras qué has encontrado.

■ PREGUNTAS DE ANÁLISIS CRÍTICO FINAL

Estas preguntas requieren REFLEXIÓN. No tienen respuesta directa en los comandos:

Pregunta 1: Priorización

Si solo pudieras corregir 3 vulnerabilidades de las que has encontrado, ¿cuáles serían? Justifica tu elección explicando el impacto de cada una.

Pregunta 2: Vectores de ataque

¿Cómo podría un atacante COMBINAR varias de estas vulnerabilidades para comprometer completamente el sistema? Describe un escenario de ataque.

Pregunta 3: Hardening

¿Qué medidas de hardening (endurecimiento) recomendarías aplicar primero? Ordena por prioridad y explica por qué ese orden.

Pregunta 4: Compensación

Imagina que NO puedes actualizar el kernel (por compatibilidad de software). ¿Qué otras medidas compensatorias implementarías para reducir el riesgo?

Pregunta 5: Detección vs Prevención

¿Cuáles de las vulnerabilidades encontradas serían detectables con un IDS/IPS? ¿Cuáles solo se pueden prevenir con buena configuración?

Pregunta 6: Contexto real

Metasploitable 2 es intencionadamente vulnerable. Si encontraras estas mismas vulnerabilidades en un servidor de producción real, ¿qué harías? ¿En qué orden?

ANEXO: REFERENCIA RÁPIDA DE COMANDOS

Propósito	Comando
Auditoría completa	<code>sudo lynis audit system</code>
Solo warnings	<code>sudo lynis show warnings</code>
Solo sugerencias	<code>sudo lynis show suggestions</code>
Ver log completo	<code>sudo cat /var/log/lynis.log</code>
Versión kernel	<code>uname -r</code>
Versión Ubuntu	<code>lsb_release -a</code>
Usuarios con shell	<code>cat /etc/passwd grep bash</code>
Config SSH	<code>sudo cat /etc/ssh/sshd_config</code>
Versión SSH	<code>ssh -V</code>
Reglas firewall	<code>sudo iptables -L -n</code>
Estado ufw	<code>sudo ufw status</code>
Permisos archivos	<code>ls -l /etc/shadow /etc/passwd</code>
Binarios SUID	<code>find /usr/bin -perm -4000 -type f</code>
Servicios activos	<code>ps aux wc -l</code>
Puertos abiertos	<code>netstat -tuln grep LISTEN</code>

¡Mucha suerte en tu investigación!

Recuerda: lo importante no es solo **ENCONTRAR** las vulnerabilidades, sino **ENTENDER** qué significan, por qué son peligrosas y cómo mitigarlas.

La ciberseguridad no es memorizar comandos, es desarrollar **pensamiento analítico**.